VulnScan Pro

Security Assessment Report

Target URL: https://juice-shop.herokuapp.com/

Scan Date: 2026-04-24 05:26:48

Overall Score: 0/100 (Grade: F)

Executive Summary

Security score is 0/100. Found 5 high severity issues.

OWASP Mapping

OWASP Category	CWE	CVSS	Finding	Severity
A03:2021 - Injection				
	CWE-79	6.1	X-XSS-Protection	MEDIUM
A05:2021 - Security Misconfiguration				
	CWE-319	7.4	Strict-Transport-Security	HIGH
	CWE-923	7.3	Port 80 open	INFO
	CWE-923	7.3	Port 443 open	INFO
	CWE-923	7.3	Port 8008 open	INFO
	CWE-693	6.1	Content-Security-Policy	HIGH
	CWE-1021	6.1	X-Frame-Options	INFO
	CWE-183	5.3	Missing SPF	MEDIUM
	CWE-693	4.3	X-Content-Type-Options	INFO
A06:2021 - Vulnerable and Outdated Components				
	CWE-1104	7.5	No WAF Detected	MEDIUM
	CWE-1104	7.5	Referrer-Policy	LOW
	CWE-1104	7.5	Permissions-Policy	LOW
	CWE-1104	7.5	Cache-Control	INFO
	CWE-1104	7.5	Favicon Hash info	INFO
	CWE-1104	7.5	Commented-out code containing sensitive keyword	MEDIUM
	CWE-1104	7.5	Hardcoded secret or password found	HIGH
	CWE-1104	7.5	Hardcoded secret or password found	HIGH
	CWE-1104	7.5	Commented-out code containing sensitive keyword	MEDIUM
	CWE-1104	7.5	Commented-out code containing sensitive keyword	MEDIUM
	CWE-1104	7.5	Commented-out code containing sensitive keyword	MEDIUM

Waf

Finding	Severity	Description	Recommendation
No WAF Detected	MEDIUM	No Web Application Firewall was detected in front of this application.	Consider deploying a WAF (e.g. Cloudflare

Port Scan

Finding	Severity	Description	Recommendation
Port 80 open	INFO	Service: HTTP	
Port 443 open	INFO	Service: HTTPS	
Port 8008 open	INFO	Service: HTTP-Alt	

Headers

Finding	Severity	Description	Recommendation
Content-Security-Policy	HIGH	Missing	Implement CSP to prevent XSS.
Strict-Transport-Security	HIGH	Missing	Enforce HTTPS connections using HSTS.
X-Frame-Options	INFO	Present	Well configured.
X-Content-Type-Options	INFO	Present	Well configured.
X-XSS-Protection	MEDIUM	Missing	Enable browser built-in XSS protection (tho
Referrer-Policy	LOW	Missing	Control referrer information sent to other si
Permissions-Policy	LOW	Missing	Restrict access to browser features like ca
Cache-Control	INFO	Present	Well configured.

Dns

Finding	Severity	Description	Recommendation
Missing SPF	MEDIUM	No SPF record found	Add SPF record

Tech

Finding	Severity	Description	Recommendation
Favicon Hash info	INFO	Hash: -1669740430 (Unknown match)	

Js Analysis

Finding	Severity	Description	Recommendation
Commented-out code could hide logic or sensitive data	MEDIUM	Found keyword in JS file: https://juice-shop.herokuapp.com/main.js	Remove commented-out code. Evidence: /api/Users/
Hardcoded secret or password found	HIGH	Found in JS file: https://juice-shop.herokuapp.com/main.js	Move secrets to server-side code. Evidence: password:"admin123"
Hardcoded secret or password found	HIGH	Found in JS file: https://juice-shop.herokuapp.com/main.js	Move secrets to server-side code. Evidence: password:"admin123"
Commented-out code could hide logic or sensitive data	MEDIUM	Found keyword in JS file: https://juice-shop.herokuapp.com/main.js	Remove commented-out code. Evidence: /rest/user/
Commented-out code could hide logic or sensitive data	MEDIUM	Found keyword in JS file: https://juice-shop.herokuapp.com/main.js	Remove commented-out code. Evidence: /rest/user/
Commented-out code could hide logic or sensitive data	MEDIUM	Found keyword in JS file: https://juice-shop.herokuapp.com/main.js	Remove commented-out code. Evidence: /rest/user/

Remediation Checklist

Follow these recommendations to improve your security posture:

• Implement CSP to prevent XSS.

• Enforce HTTPS connections using HSTS.

• Move secrets to server-side environment variables. Never include credentials in JavaScript.